

Unifolio — Information Security Policy

Document owner: Ahmed Al-Samak, CEO (security@unifolio.ca)

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Review cadence: Annually, or upon material change to architecture, vendors, or regulatory requirements.

1. Purpose & Scope

This policy defines how **Unifolio Inc.** (operator of unifolio.ca and unifolio.pro, hereafter "Unifolio") identifies, mitigates, and monitors information-security risks. It applies to:

- All Unifolio production systems and the data they process.
- All personnel (currently: founder + occasional contractors) who interact with production systems.
- All third-party vendors that store, transmit, or process Unifolio user data.

Unifolio is a **read-only personal portfolio aggregator** for Canadian retail investors. It does not custody assets, execute trades, or transmit money. Its security posture is calibrated accordingly.

2. Roles & Responsibilities

Role	Person	Responsibility
CEO / Security Officer	Ahmed Al-Samak	Final accountability for information security, vendor risk, incident response, and policy review.
Engineering	Ahmed Al-Samak (with AI-assisted code review)	Implementation of security controls in code; vulnerability triage; deployment.
External counsel (on call)	Engaged ad hoc	Privacy law (PIPEDA, GDPR), incident notification obligations.

Security questions and incident reports go to **security@unifolio.ca** (monitored daily by Ahmed).

3. Risk Classification

Information Security Policy · Unifolio Inc. · Generated 2026-05-14 · Canonical version: github.com/2uay/unifolio
Unifolio classifies data by sensitivity:

Class	Examples	Handling
Class A — User financial data	Holdings, transactions, account balances, Plaid <code>access_token</code> , broker import files	Encrypted at rest (Supabase AES-256), encrypted in transit (TLS 1.2+), Postgres Row-Level Security enforced per-user, never logged in plaintext
Class B — User identity data	Email, name, profile photo, password hash	Same as Class A; passwords hashed by Supabase Auth (bcrypt) and never visible to Unifolio code
Class C — Operational data	Vendor API keys, Supabase service-role keys, database credentials	Stored only in environment-variable secret stores (Vercel encrypted env vars); never committed to source control
Class D — Public data	Marketing pages, blog, public documentation	No special protection beyond standard web hardening

4. Access Controls

4.1 User-facing access

- Authentication via **Supabase Auth** (email + password); minimum 8-character password length and rate-limited authentication attempts to defeat brute-force guessing. HavelBeenPwned breach-corpus checking is a Supabase Pro feature and will be enabled when Unifolio upgrades from Free.
- Postgres **Row-Level Security (RLS)** policies on every Supabase table containing Class A or B data — confirmed enabled on `accounts`, `holdings`, `transactions`, `realized_positions`, `import_batches`, `user_profiles`, `plaid_items`, `watchlist`, `custom_assets`, `audit_log`. Each policy enforces `user_id = auth.uid()`.
- **MFA via TOTP** is available to every user through Supabase Auth's `auth.mfa.*` flow; users enroll an authenticator-app factor from **Settings → Security & Privacy → Two-Factor Authentication**, and authenticated sessions are upgraded to AAL2 via a 6-digit challenge after password sign-in. For accounts created on or after **2026-09-30**, enrollment of at least one verified TOTP factor is **mandatory before the user can connect a Plaid Item**. Accounts created before that date are grandfathered (existing users are encouraged but not forced to enroll, to avoid stranding active connections). Email verification continues to gate account activation for every user regardless of cohort.

4.2 Administrative access

- Production console access (Vercel, Supabase, GitHub, GoDaddy, Microsoft 365 admin) is restricted to the CEO and protected by **multi-factor authentication on every provider**.

- Supabase **service-role keys** are only accessible to server-side code (Vercel serverless functions, Supabase Edge Functions). The browser only ever sees the public **anon** key, which is restricted by RLS.
- Production database direct access is only used for incident investigation; routine queries go through application code.
- **Principle of least privilege** is enforced per-vendor: Vercel deploy hooks, Supabase API keys, and Plaid keys are scoped to the minimum permissions required.

4.3 Provisioning / de-provisioning

- New contractors (rare) are granted access only to the specific tools required for their scoped task and revoked at task completion.
- Vendor API keys are rotated when (a) a contractor with access leaves, (b) a credential is suspected of exposure, (c) annually as a baseline.

5. Network & Infrastructure Security

- All traffic to Unifolio is served over **HTTPS with TLS 1.3** (Vercel-managed certificates from Let's Encrypt; HSTS enforced).
- All Supabase API traffic uses TLS 1.2+ (Supabase enforces this server-side).
- All Plaid API traffic uses TLS 1.2+ (Plaid enforces this).
- Vercel + Supabase run in dedicated AWS regions with **AWS-level network isolation** and **AWS KMS-managed encryption at rest** (AES-256).
- No self-hosted infrastructure: every system is a managed cloud service whose underlying patching, hardening, and physical security is handled by the vendor.

6. Data Lifecycle

6.1 Collection

Data is collected only via:

1. User-initiated account signup (email, name).
2. User-initiated CSV/Flex broker import (positions, transactions).
3. User-authorized Plaid Link connection (via Plaid's consent flow).

Once a Plaid connection exists, Plaid asynchronously notifies Unifolio of new holdings, investment transactions, and item error events via signed webhooks (**/api/plaid/webhook**). The endpoint verifies every inbound payload using Plaid's JWT signature scheme (ES256, JWK fetched per **kid**) and a SHA-

256 hash of the raw request body before any data is read or written; unverified payloads are dropped. Webhook-driven re-syncs reuse the same server-side normalization path as user-initiated syncs, so no new data categories are introduced. Item-error states (`ITEM_LOGIN_REQUIRED` , `PENDING_EXPIRATION` , `USER_PERMISSION_REVOKED`) are surfaced to the affected user with an in-app reconnect affordance backed by Plaid's update-mode link tokens — re-authentication preserves the existing `access_token` and historical data.

6.2 Processing

All Class A/B processing happens server-side in Vercel serverless functions or Supabase Postgres. No third-party analytics tracker has access to financial data.

6.3 Storage

Class A/B data is stored only in Supabase Postgres (AWS `us-east-2` / Ohio region). Plaid `access_token` values are stored in the `plaid_items` table with RLS restricting access to the owning user.

6.4 Retention & deletion

See companion document [DATA_RETENTION_POLICY.md](#).

6.5 Backups

Supabase performs automated database backups according to its tier policy. Backup storage is encrypted by AWS KMS; access is restricted to Supabase staff under their SOC 2 controls. Unifolio is currently on the Supabase Free tier, which provides daily automated backups; point-in-time recovery (PITR) and longer retention will be enabled when Unifolio upgrades to Supabase Pro (planned trigger: first ≥5 paying users or any incident requiring sub-day recovery, whichever comes first).

7. Vulnerability Management

Practice	Tooling	Cadence
Dependency vulnerability scanning	GitHub Dependabot (<code>.github/dependabot.yml</code>) + <code>npm audit</code> at every build	Weekly (Dependabot) + per build
OS / runtime patching	Vercel + Supabase managed platforms	Continuous (vendor-managed)

Practice	Tooling	Cadence
Endpoint hardening (founder MacBook)	macOS automatic security updates, FileVault disk encryption, password-protected screen lock, automatic lock after 5 min idle	Continuous
Code review	Manual review on every PR + AI-assisted review (Claude Code)	Per change
Secrets scanning	GitHub native push-protection + manual review	Per push

Critical vulnerabilities (CVSS ≥ 9.0) are triaged within **48 hours**, patched within **7 days**. High-severity (CVSS 7.0–8.9) within **30 days**. Medium and below as part of the regular update cadence.

8. Incident Response

8.1 Definitions

A **security incident** is any event that compromises (or could compromise) the confidentiality, integrity, or availability of Class A/B data, or the proper functioning of authentication or authorization.

8.2 Reporting

Incidents are reported to **security@unifolio.ca** (Ahmed) by:

- Internal detection (logs, alerts, code review)
- Vendor notification (Supabase, Vercel, Plaid security teams)
- External report (user email, security researcher)

8.3 Process

1. **Acknowledge** within 4 hours of report.
2. **Triage** severity within 24 hours.
3. **Contain** immediately for any active exploitation (rotate keys, disable affected components).
4. **Notify** affected users within **72 hours** of confirmed Class A/B data exposure (PIPEDA compliance).
5. **Notify Plaid** within the timeline required by the Plaid Production Customer Agreement.
6. **Notify regulators** as required by applicable Canadian privacy law.
7. **Remediate** the root cause; document the timeline + mitigations in `docs/incidents/<date>-<slug>.md`.
8. **Post-mortem** internally within 30 days; share lessons learned externally if appropriate.

9. Vendor / Third-Party Risk

Vendor	Service	Data shared	Their security posture
Supabase	Postgres + Auth + Storage + Edge Functions	All Class A/B	SOC 2 Type II, GDPR/CCPA compliant, AES-256 at rest
Vercel	Hosting + DNS + serverless functions	App code, environment variables	SOC 2 Type II, ISO 27001
Plaid	Account aggregation API	User-authorized broker access tokens	SOC 2 Type II, ISO 27001, ISO 27018
Finnhub	Public market quote API	Ticker symbols only (no user data)	Standard commercial API
Microsoft 365 (via GoDaddy reseller)	Email	Internal correspondence	SOC 2 Type II, FedRAMP
GoDaddy	Domain registrar	Domain registration metadata only	Industry-standard registrar controls
Anthropic / OpenAI	AI assistance for development only	Code excerpts, no user data	SOC 2 Type II

Vendors are reviewed annually or upon material change to the relationship.

10. Privacy & Regulatory Compliance

- Unifolio complies with **PIPEDA** (Canada) for Canadian user data.
- For users in the EU/UK, Unifolio acts as a data controller under **GDPR** principles: lawful basis (contract performance + consent), data minimization, user rights (access, rectification, deletion, portability).
- Privacy disclosure: published at <https://unifolio.ca/privacy> and reviewed annually.
- Plaid integration follows the Plaid Production Customer Agreement and Plaid's User Privacy Policy template.

11. Training & Awareness

Information Security Policy · Unifolio Inc. · Generated 2026-05-14 · Canonical version: github.com/2uay/unifolio

- The CEO maintains current knowledge of OWASP Top 10, Plaid security best practices, and Canadian privacy law via ongoing self-study.

- Any future contractors are required to acknowledge this policy and complete a 30-minute self-paced security review before being granted any production access.
-

12. Policy Review & Amendment

This policy is reviewed:

- **Annually** by the CEO at minimum.
- **On any material change** to architecture, vendors, regulatory environment, or following any security incident.

Material changes are version-controlled in the project Git repository (`docs/INFOSEC_POLICY.md`); the change log is the file's commit history.

Acknowledgement

By committing this document to the Unifolio repository, the CEO formally acknowledges and adopts this policy on behalf of Unifolio Inc.

— Ahmed Al-Samak, CEO, Unifolio Inc.

2026-05-13